



Activity File: Windows Password Spraying

In this activity, you will continue to play the role of a pen tester conducting an engagement on MegaCorpOne. Now that you've recognized which machines on MegaCorpOne's network are Windows machines, you will perform your first attack: password spraying.

In the previous module, you cracked several passwords belonging to the users from the `/etc/shadow` file on the Linux machine. Now, you'll attempt to use those to log in to a Windows machine. The password spraying technique will use the SMB protocol and a Metasploit auxiliary module for SMB logins. Since you will attempt to log in to a domain account, Windows will perform Kerberos authentication.

- You will use Metasploit to perform a password spray attack on the Windows machines that you discovered from your Nmap scans.
- The goal of this activity is to find a working set of credentials for the target machines that you can use later on to gain access to the machine.

 **Reminder:** Don't forget to save your findings, as you will add them to your Week 16 Homework!

Instructions

On your Kali machine, open Metasploit and load the `auxiliary/scanner/smb/smb_login` module, as the image shows:

```
msf6 exploit(nix/misc/distcc_exec) > use auxiliary/scanner/smb/smb_login
msf6 auxiliary(scanner/smb/smb_login) > options

Module options (auxiliary/scanner/smb/smb_login):
```

Name	Current Setting	Required	Description
ABORT_ON_LOCKOUT	false	yes	Abort the run when an account lockout is detected
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DETECT_ANY_AUTH	false	no	Enable detection of systems accepting any authentication
DETECT_ANY_DOMAIN	false	no	Detect if domain is required for the specified user
PASS_FILE		no	File containing passwords, one per line
PRESERVE_DOMAINS	true	no	Respect a username that contains a domain name.
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RECORD_GUEST	false	no	Record guest-privileged random logins to the database
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT	445	yes	The SMB service port (TCP)
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

```
msf6 auxiliary(scanner/smb/smb_login) > █
```

Referencing your notes, refer back to the usernames and passwords you cracked from the /etc/shadow file on the Linux machine. You will try to use each of these credentials in attempts to find a set that works on a machine.

1. Set the SMBUser and SMBPass to a set of credentials you cracked from the /etc/shadow file.
2. Referencing your nmap/zenmap scans, set SMBDomain to the domain of the Windows 10 machine. (If the domain is lab.local, for example, the domain would just be **lab**.)
3. Set RHOSTS to the entire subnet in CIDR notation (e.g., x.x.x.x/24).

```
msf6 auxiliary(scanner/smb/smb_login) > options

Module options (auxiliary/scanner/smb/smb_login):
```

Name	Current Setting	Required	Description
ABORT_ON_LOCKOUT	false	yes	Abort the run when an account lockout is detected
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
DETECT_ANY_AUTH	false	no	Enable detection of systems accepting any authentication
DETECT_ANY_DOMAIN	false	no	Detect if domain is required for the specified user
PASS_FILE		no	File containing passwords, one per line
PRESERVE_DOMAINS	true	no	Respect a username that contains a domain name.
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RECORD_GUEST	false	no	Record guest-privileged random logins to the database
RHOSTS	192.168.1.1/24	yes	The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT	445	yes	The SMB service port (TCP)
SMBDomain	LAB	no	The Windows domain to use for authentication
SMBPass	ExamplePassword	no	The password for the specified username
SMBUser	ExampleUser	no	The username to authenticate as
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

4. Run the attack. What machines could it successfully log in to?
5. Open the WINDC01 VM in Hyper-V and attempt to log in with those credentials. Are you able to successfully log in?
6. What is the domain for the account you just password sprayed?